GROUP C PENTEST WORK FLOW

A. NMAP

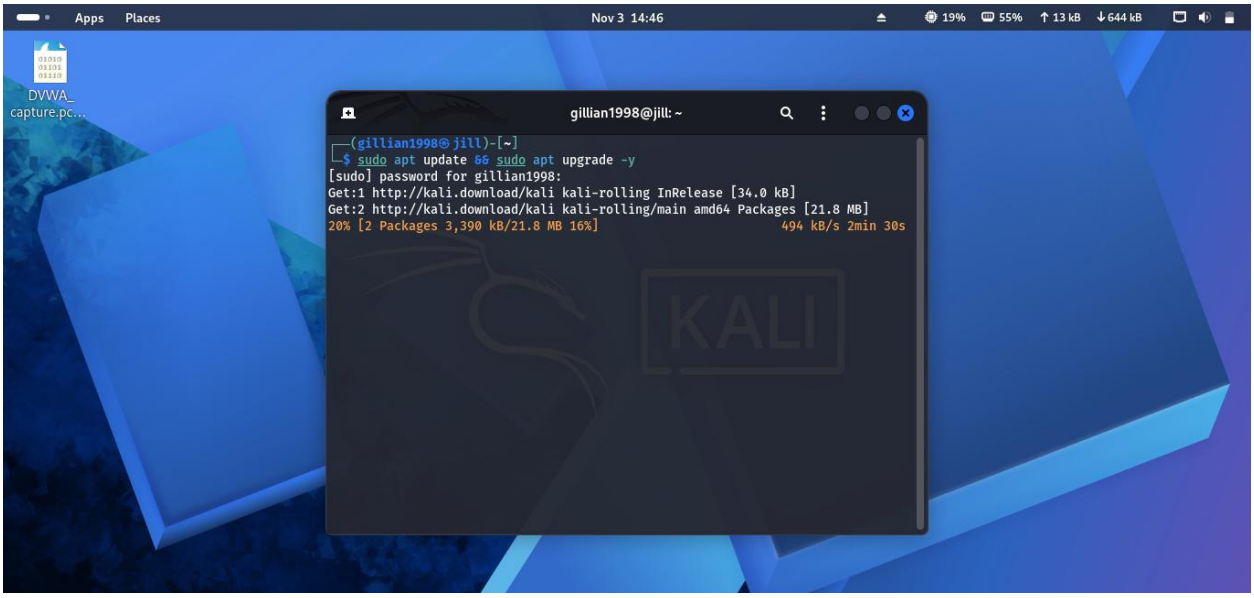
Overall Objective: To scan available ports and services.

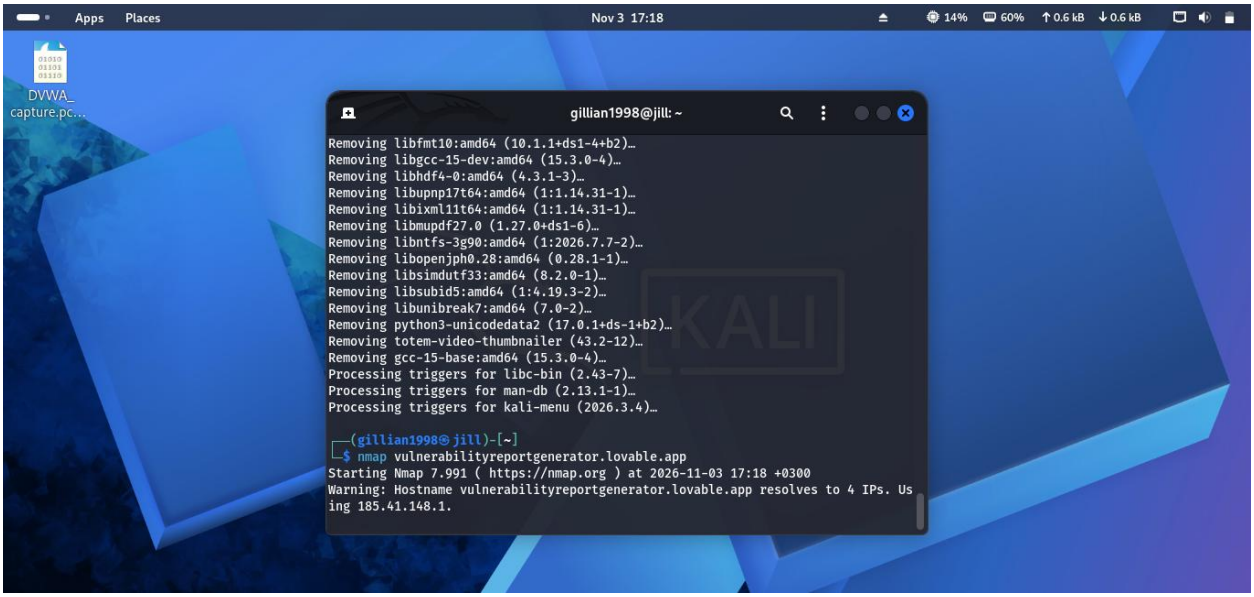
Method: Active Network reconnaissance

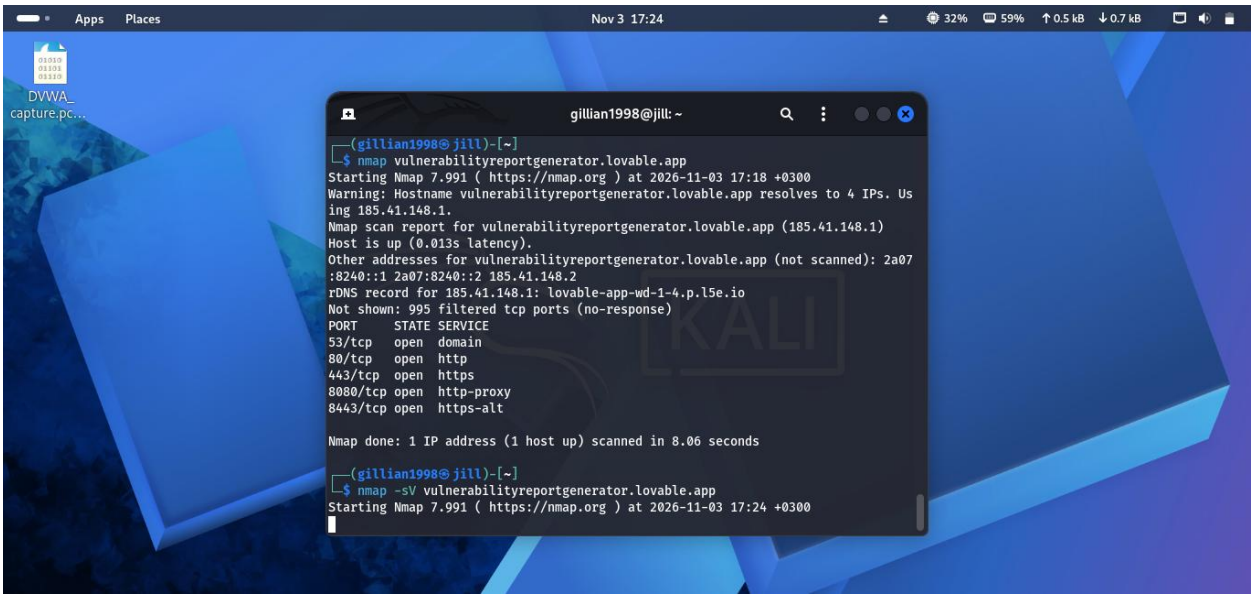
STEPS

1. Identifying the target host: https://vulnerabilityreportgenerator.lovable.app
2. Extract host name: vulnerabilityreportgenerator.lovable.app
3. Perform a basic Nmap scan using the kali linux terminal:
   CODE:
   >>sudo apt update && sudo apt upgrade -y
   >>nmap vulnerabilityreportgenerator.lovable.app

   Objective: To check common ports and identify which ones are open.







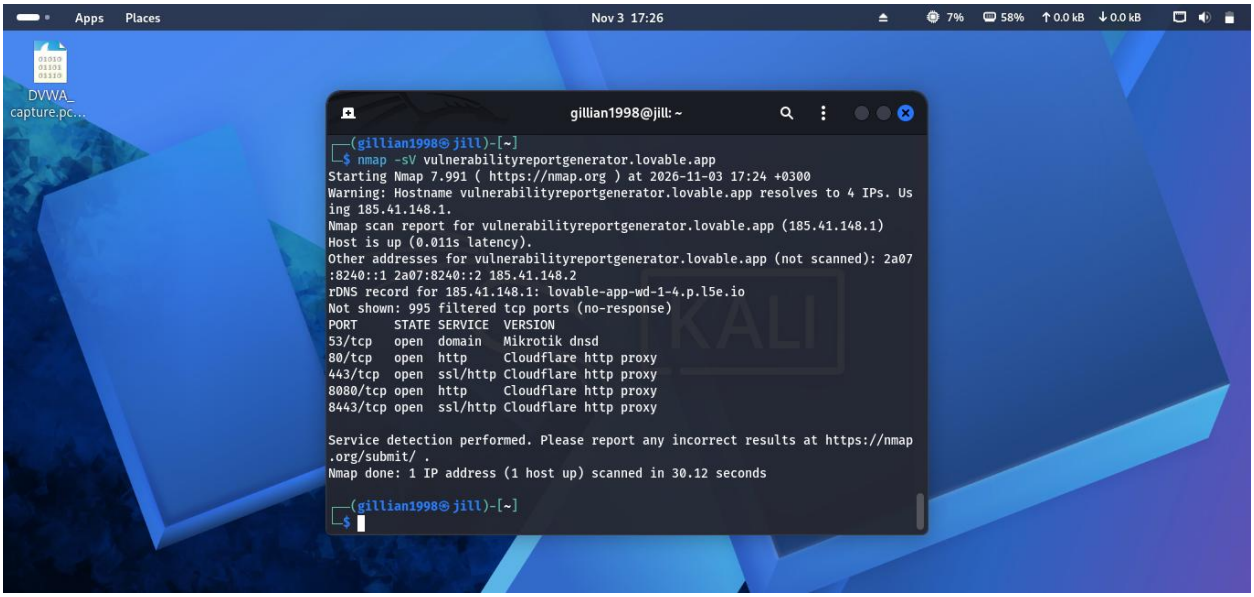
OPEN PORTS/SERVICES IDENTIFIED: 53/tcp-domain, 80/tcp-http, 443/tcp-https, 8080/tcp-http-proxy, 8443/tcp-https-alt

4. Service detection

   CODE:

   >> nmap -sV vulnerabilityreportgenerator.lovable.app

   Objective: To identify service versions running on open ports.



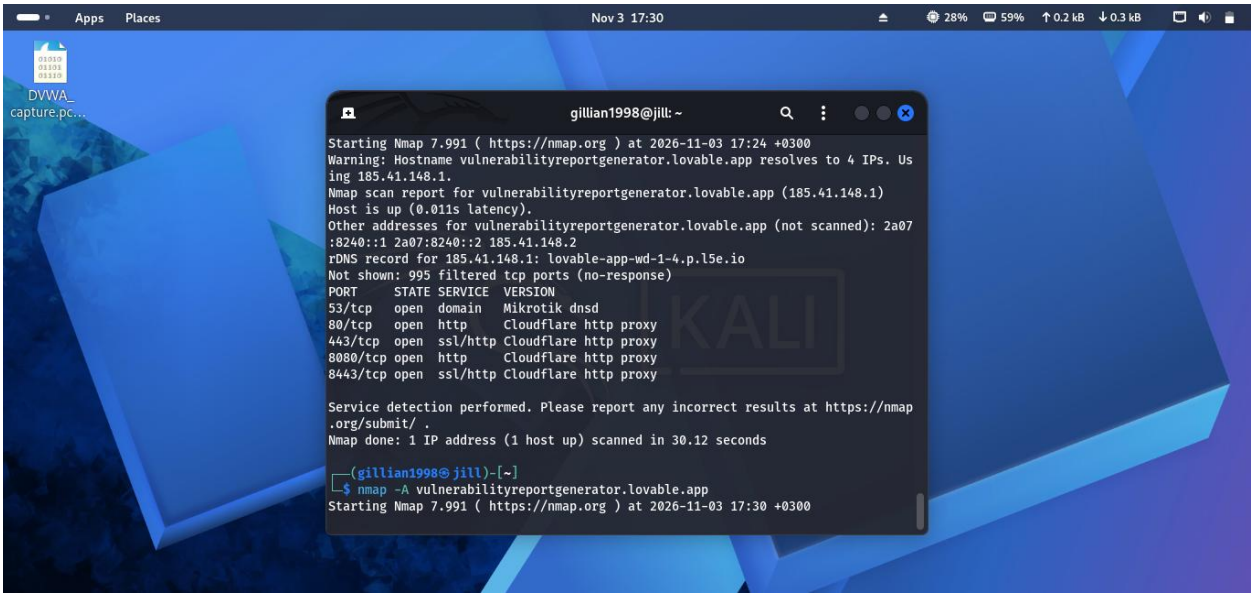
PORT	SERVICE	VERSION
53/tcp	Domain	Mikrotik dnsd
80/tcp	http	Cloudflare http proxy
443/tcp	ssl/http	Cloudflare http proxy
8080/tcp	http	Cloudflare http proxy
8443/tcp	ssl/http	Cloudflare http proxy

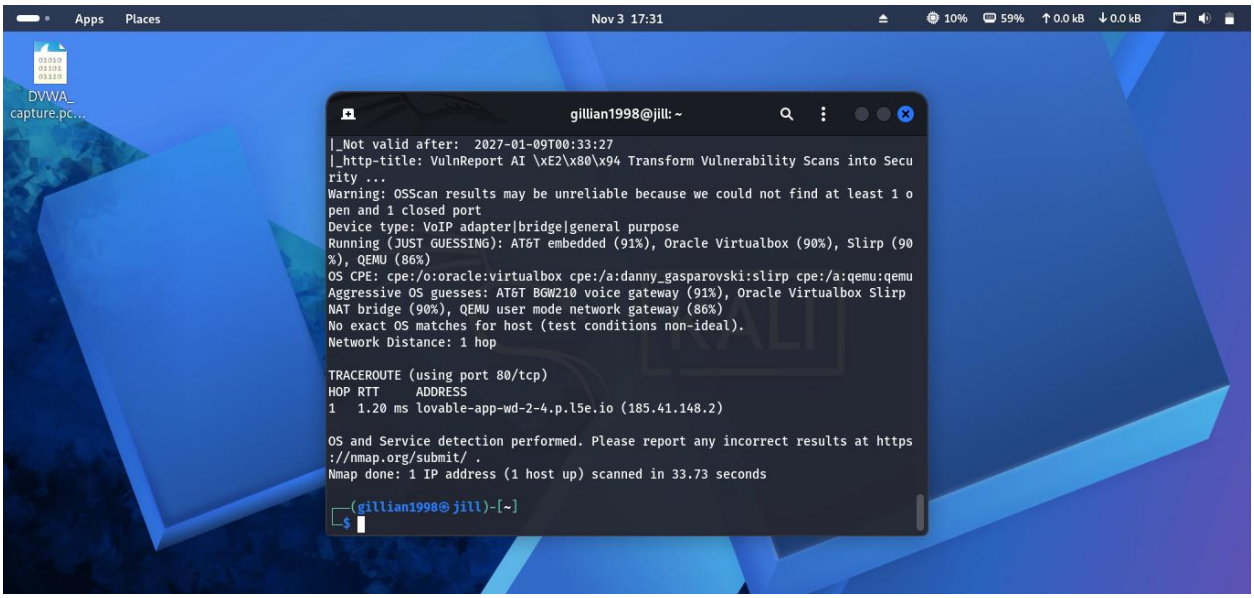
5. Aggressive enumeration

   CODE:

   >> nmap -A vulnerabilityreportgenerator.lovable.app

   Objective: Identify OS system and version running on target device, determine service versions of open ports, script scanning (running predefined NSE scripts for further enumeration) and trace route (mapping the network path to the target).

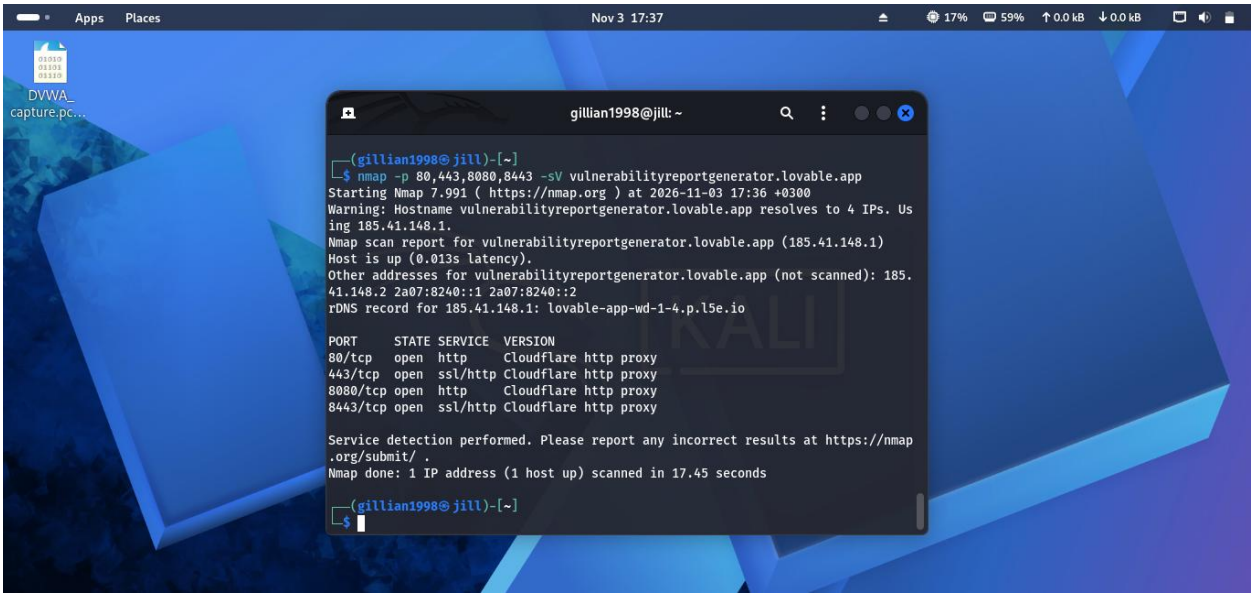




FINDINGS: No OS system identified running on target device

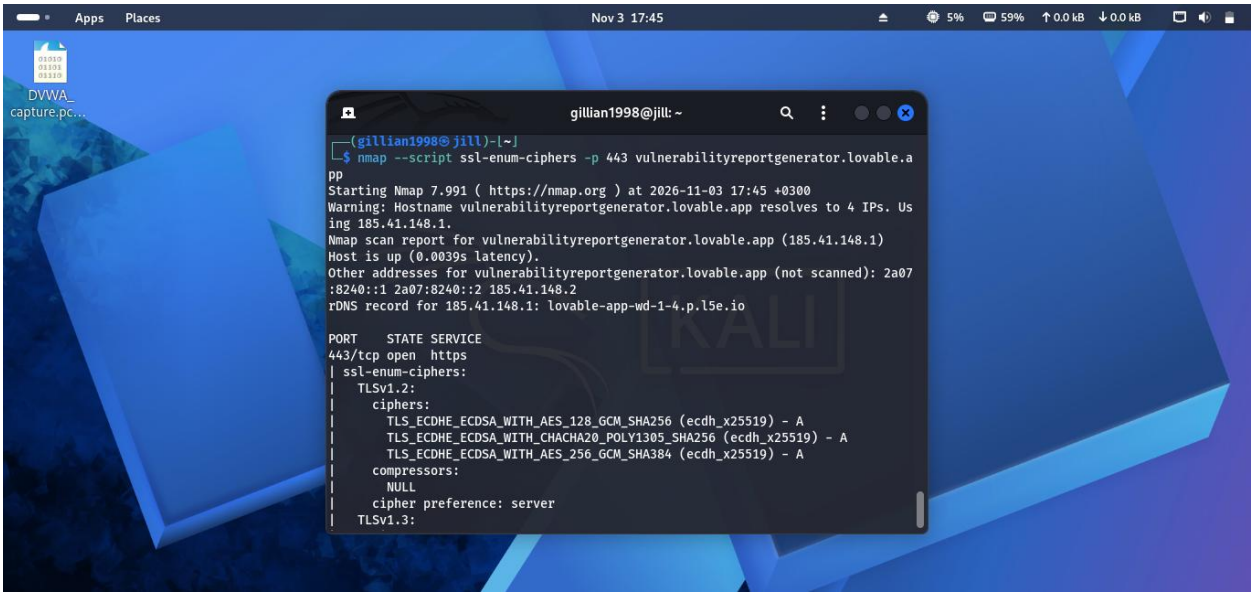
6. Scan common web ports
   CODE:
   >>nmap -p 80,443,8080,8443 -sV vulnerabilityreportgenerator.lovable.app

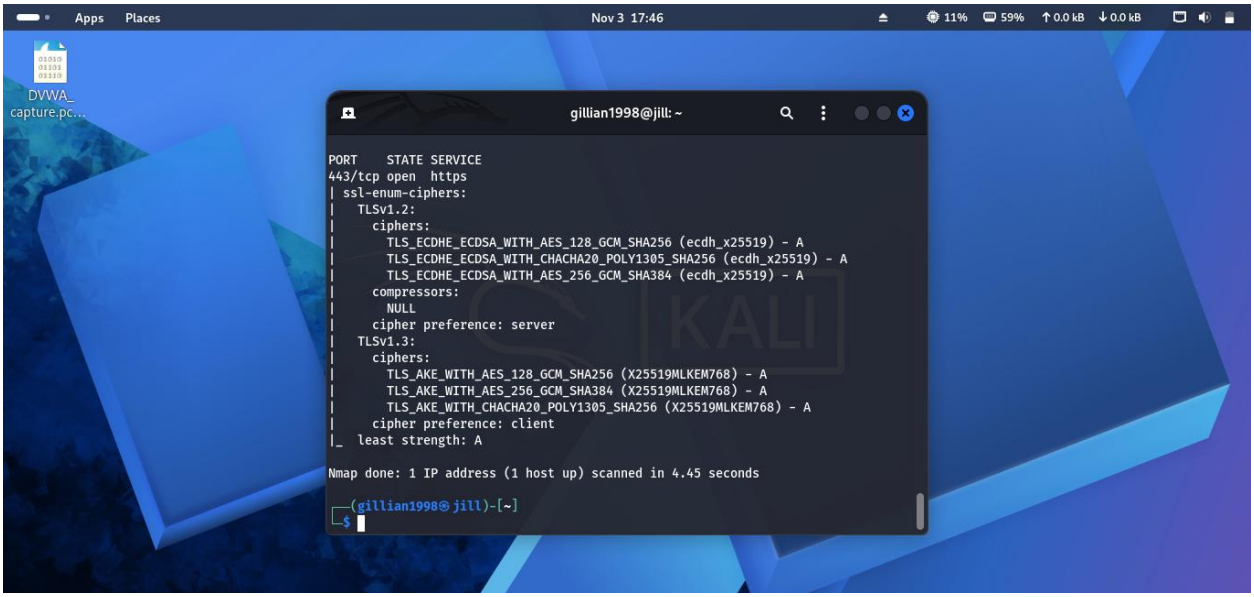
   Objective: Identify web services and alternate HTTP ports



7. SSL/TLS assessment
   CODE:
   >> nmap –script ssl-enum-ciphers -p 443 vulnerabilityreportgenerator.lovable.app

   OBJECTIVE: To check supported TLS versions, Cipher suites and weak encryption settings.

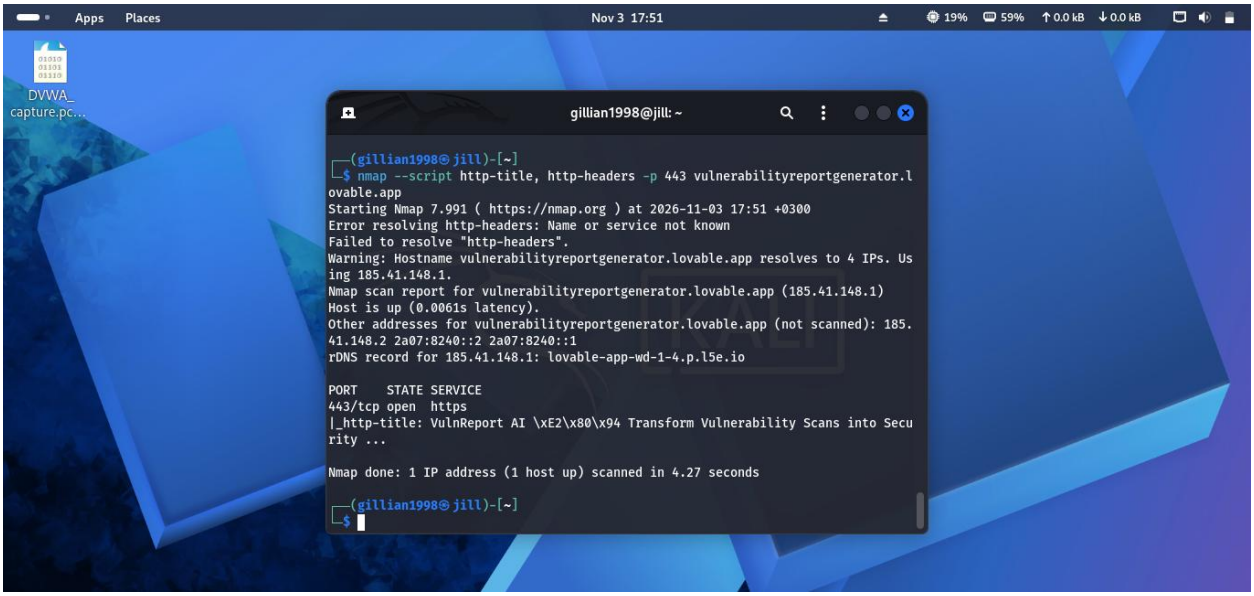




FINDINGS: Identified TLS version 1.2 and TLS version 1.3

8. HTTP information gathering
   CODE:
   >>> nmap –script http-title, http-headers -p 443
   vulnerabilityreportgenerator.lovable.app

   OBJECTIVE: To show page title, server headers and basic web fingerprinting



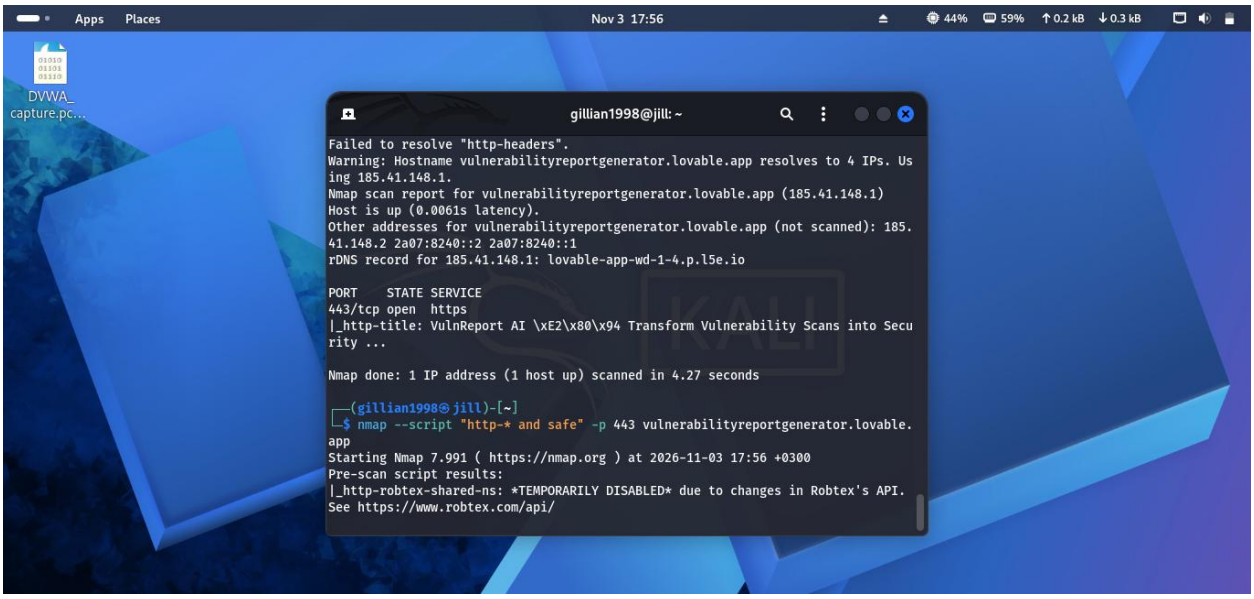
FINDINGS: Unable to retrieve http-header.

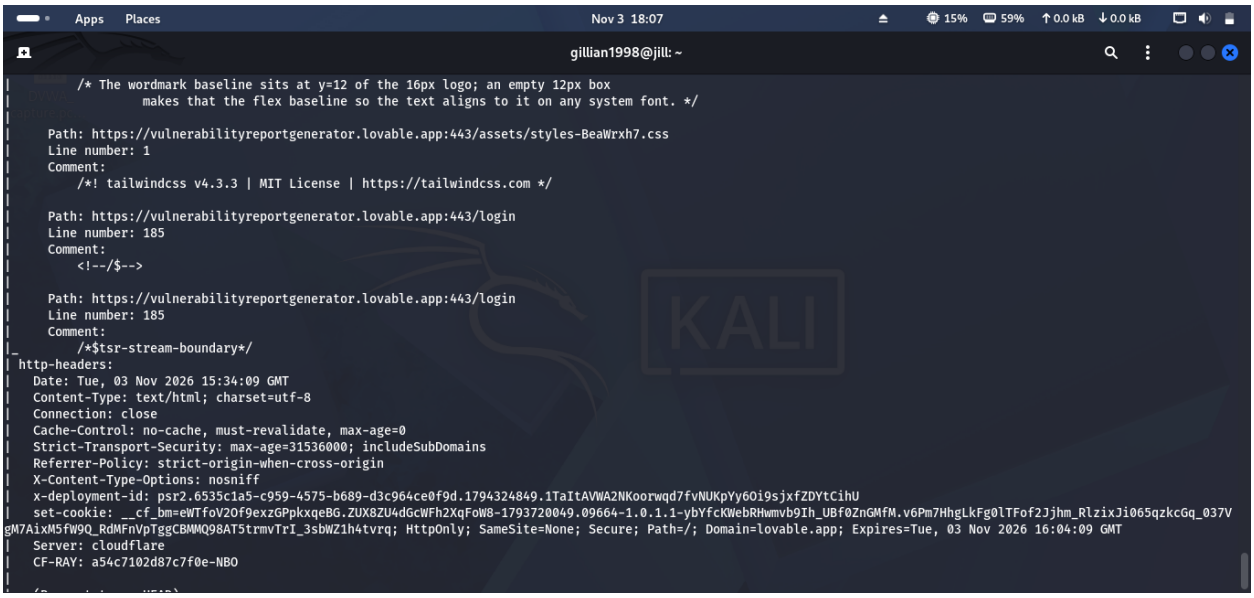
9. Run safe web vulnerability scripts

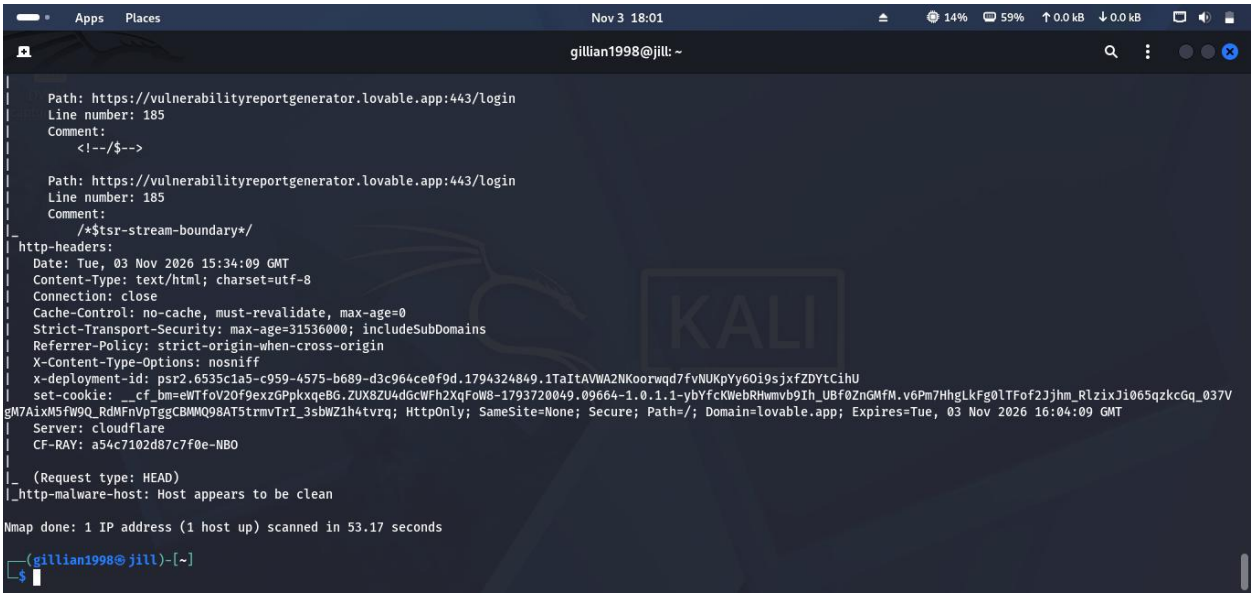
   CODE:

   >>nmap –script “http-* and safe” -p 443 vulnerabilityreportgenerator.lovable.app

   OBJECTIVE: Runs Nmap’s safer HTTP NSE scripts without actively exploiting anything.







10. Check for known vulnerabilities

    CODE:

    >> nmap --script vuln vulnerabilityreportgenerator.lovable.app

    OBJECTIVE: Compare detected service versions against known vulnerability databases.



    FINDINGS: No vulnerabilities detected.

11. Save results

    CODE:

>>nmap -A -oN scan_results.txt vulnerabilityreportgenerator.lovable.app

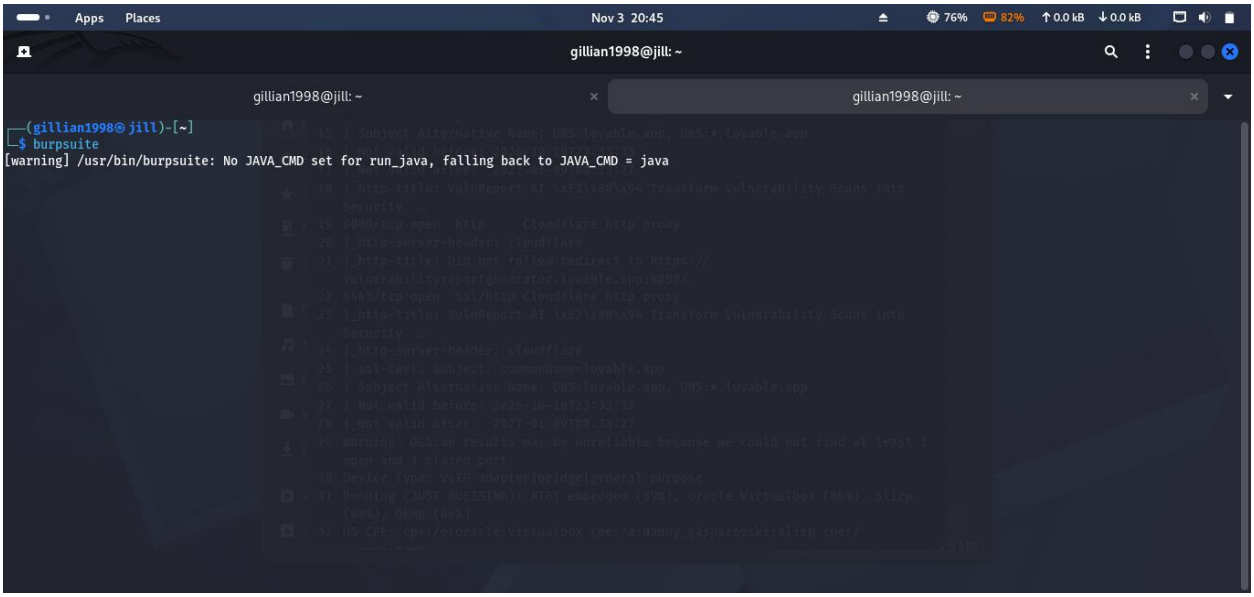


B. BURPSUITE

Overall Objective: Input validation testing, Authentication testing and session management testing.

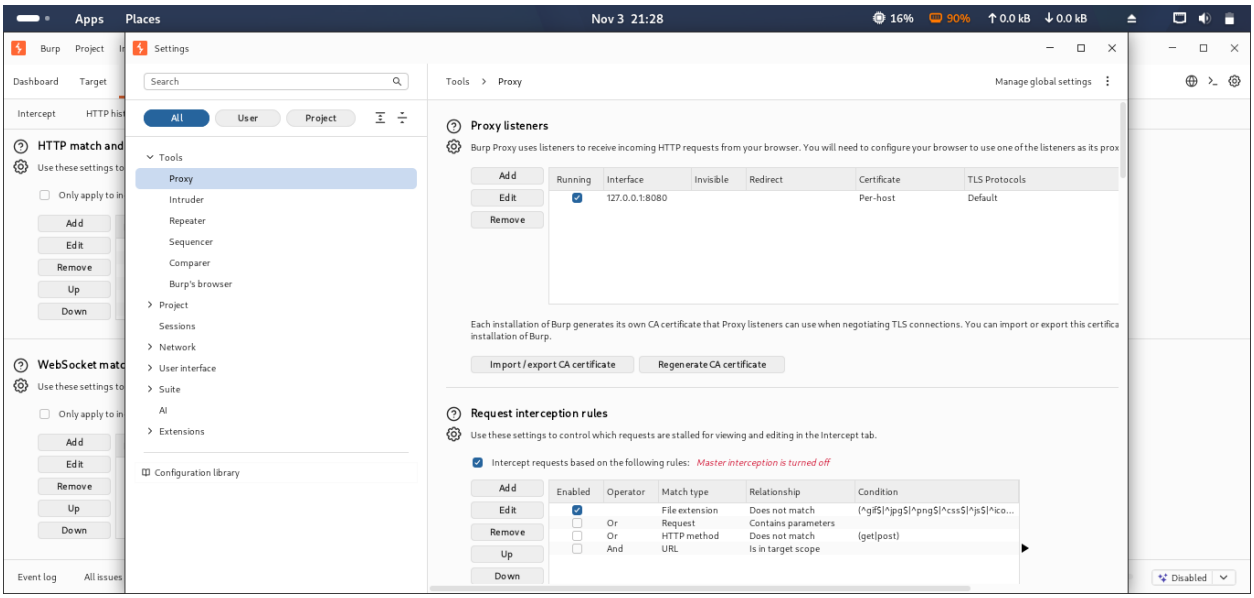
STEPS

1. Start Burp Suite
   Terminal Code:
   >>burpsuite



2. Configure browser

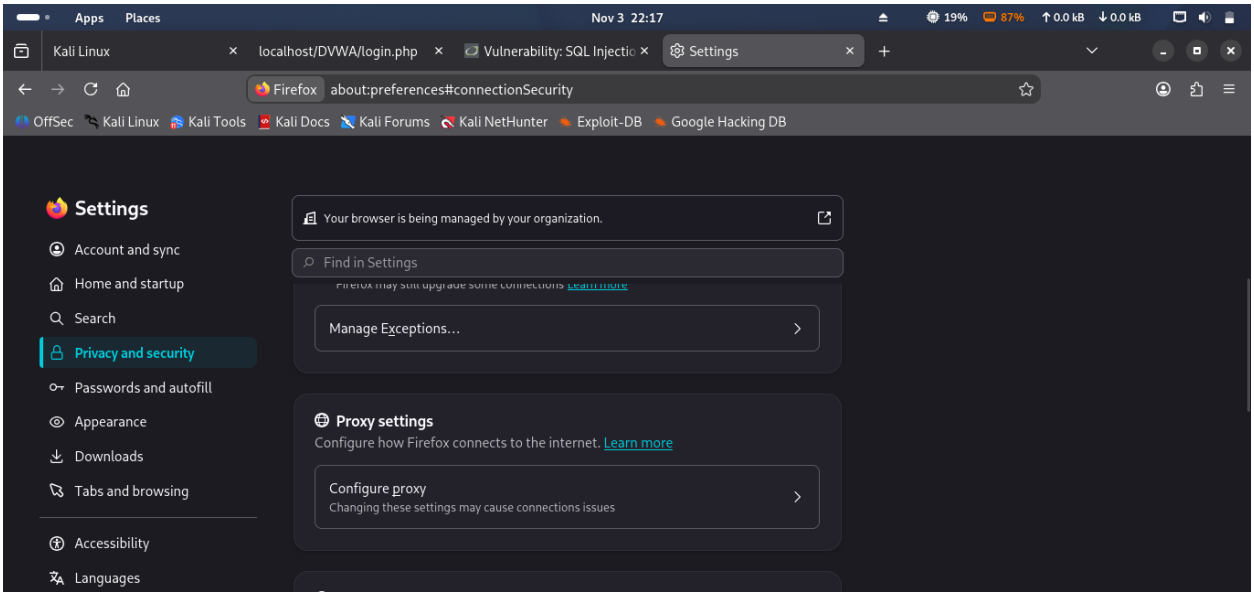
In Burp, select **Proxy -> Proxy settings,** confirm burp is listening on port:**127.0.0.1:8080.**

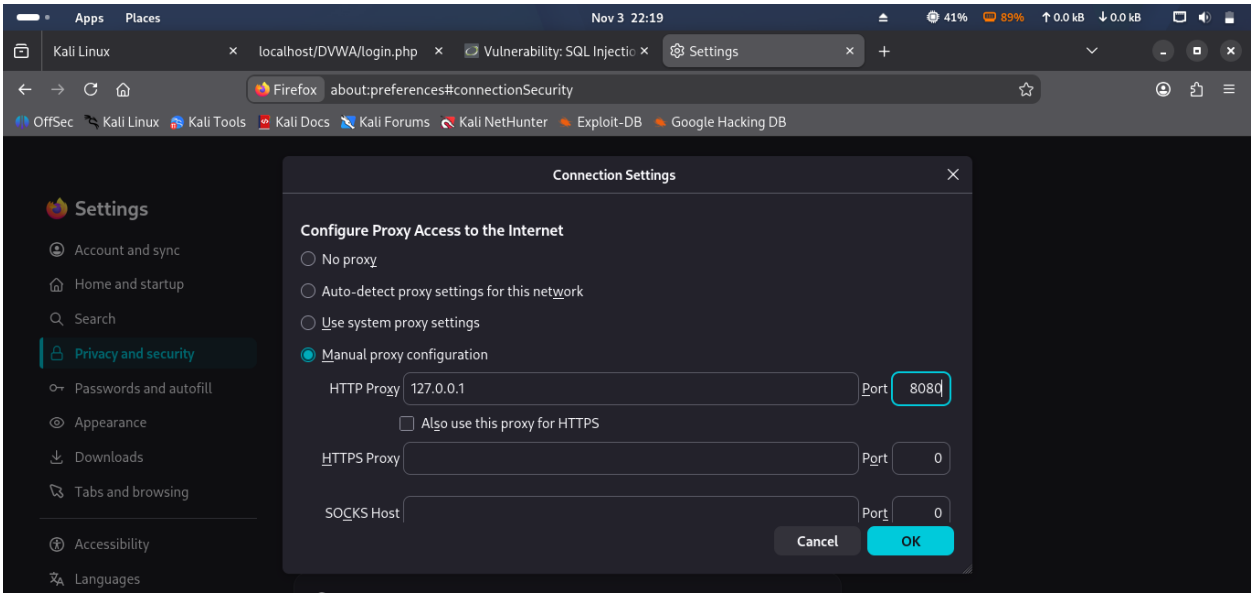


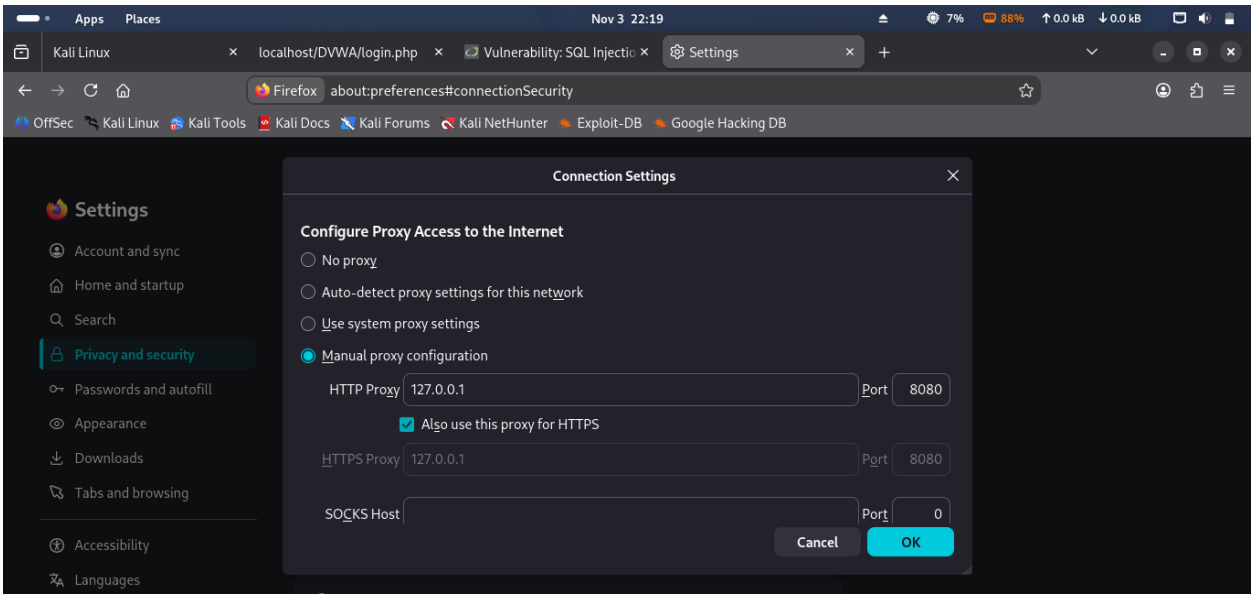
Configure Firefox browser to use:

HTTP Proxy: 127.0.0.1

Port: 8080

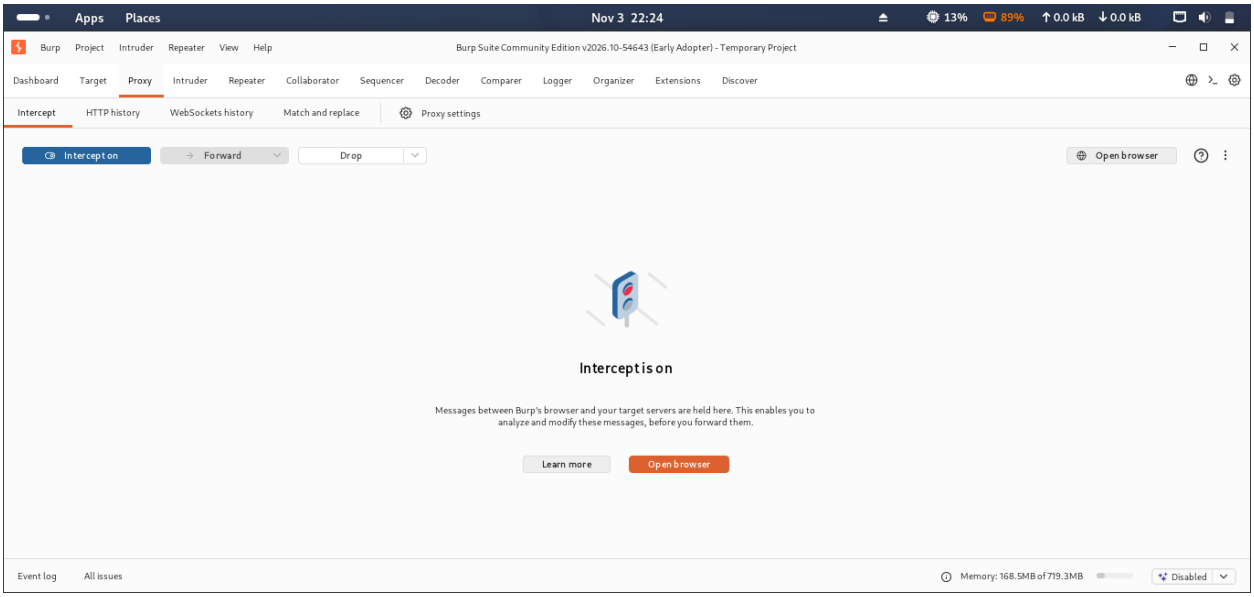




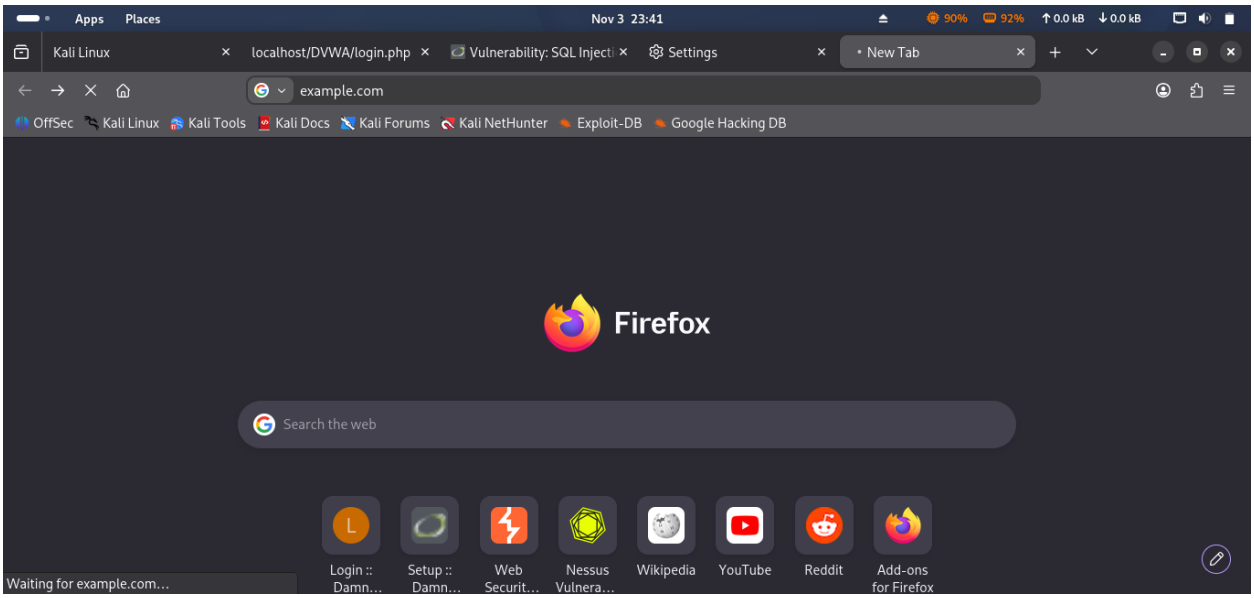


3. Intercept traffic

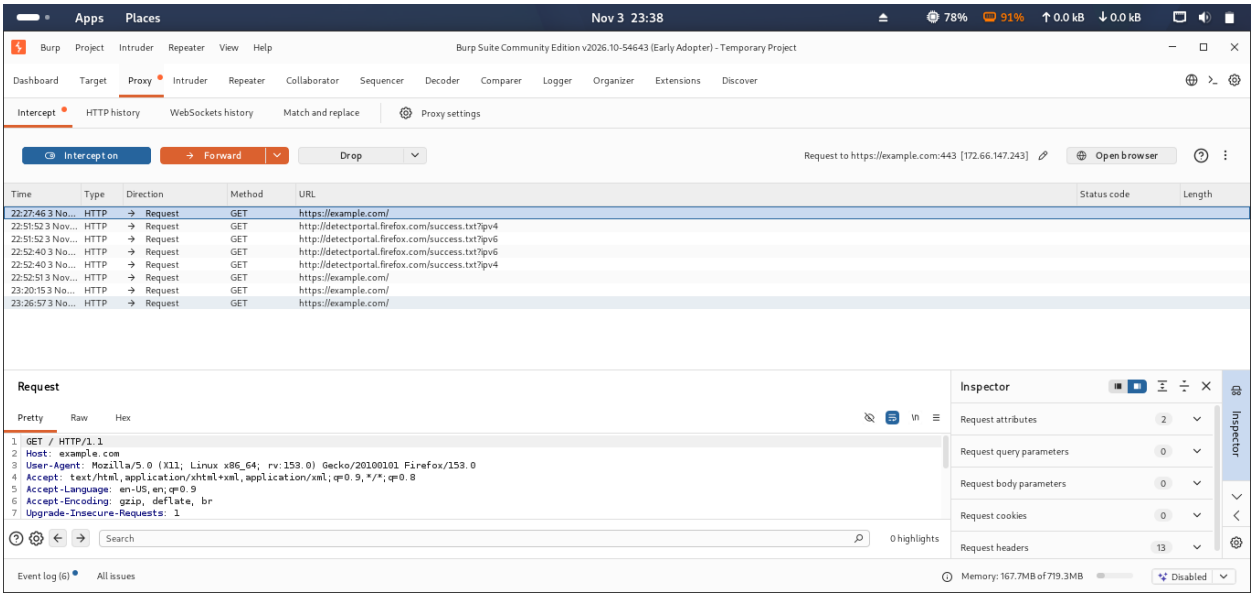
   In Burp: choose **Proxy->Intercept->Intercept is ON**



Test the proxy: visit https://example.com in Firefox.



To show that it’s configured correctly: the page pauses, burp displays a http request and Firefox will wait for response.



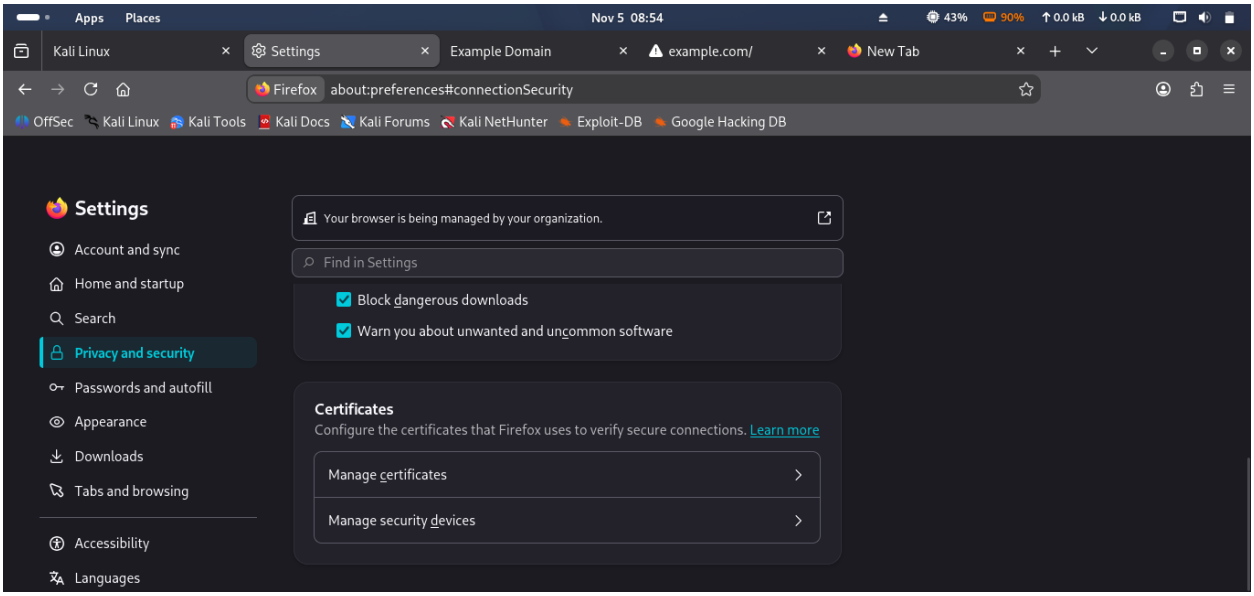
Clicking **forward** loads the page.

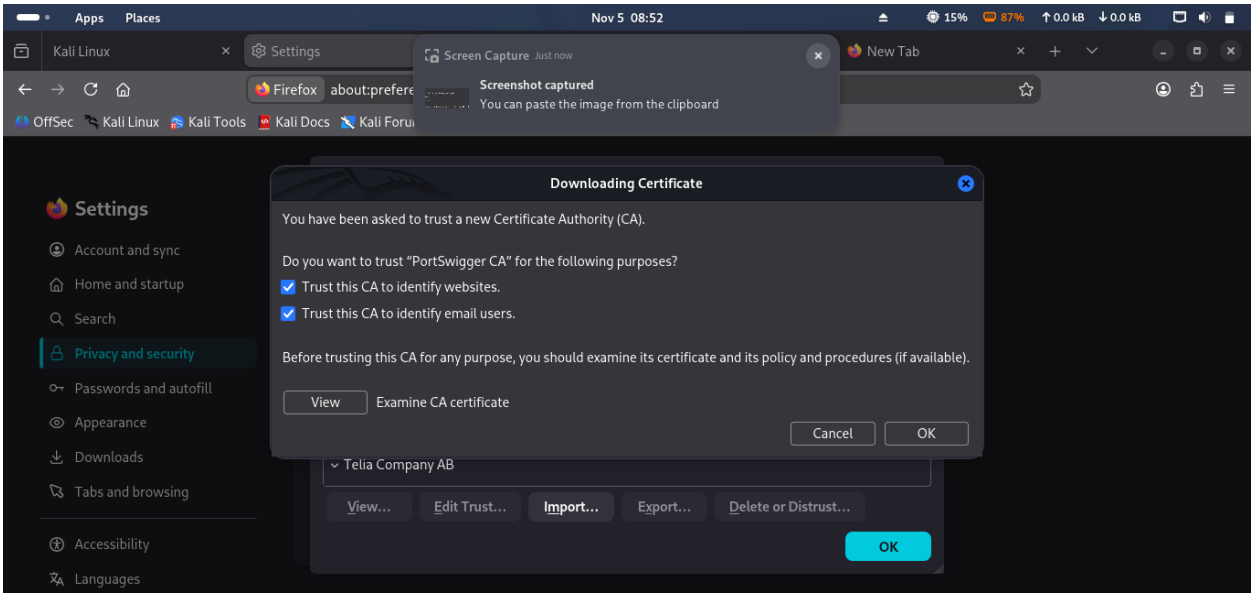
4. Install Burp's CA Certificate (Required for HTTPs)

   Without Burp's certificate, Firefox shows HTTPs certificate warnings.

   Visit http://burpsuite and download the CA certificate.

   Import the certificate into Firefox: **Settings->Privacy&Security**, scroll certificates->manage certificates->Authorities->Import->Trust this CA to identify websites->OK



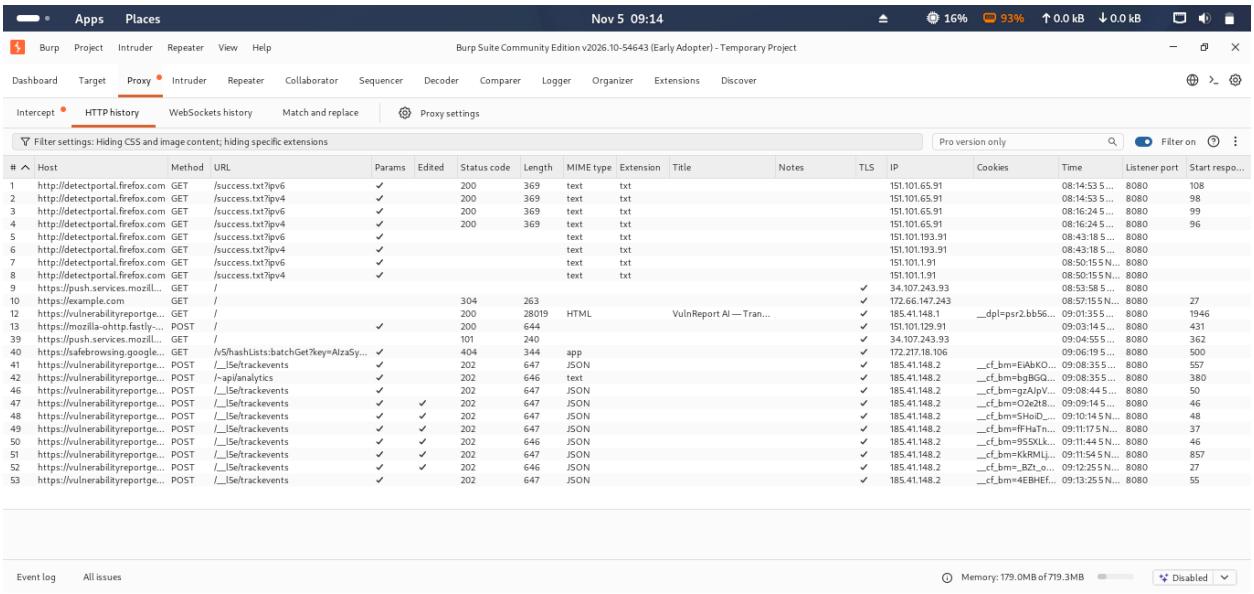


5. Browse the target app

   Target: http://vulnerabilityreportgenerator.lovable.app

   Burp captures: logins, API requests, file uploads, response headers and session cookies.

   This can be viewed under: **Proxy->HTTP history**

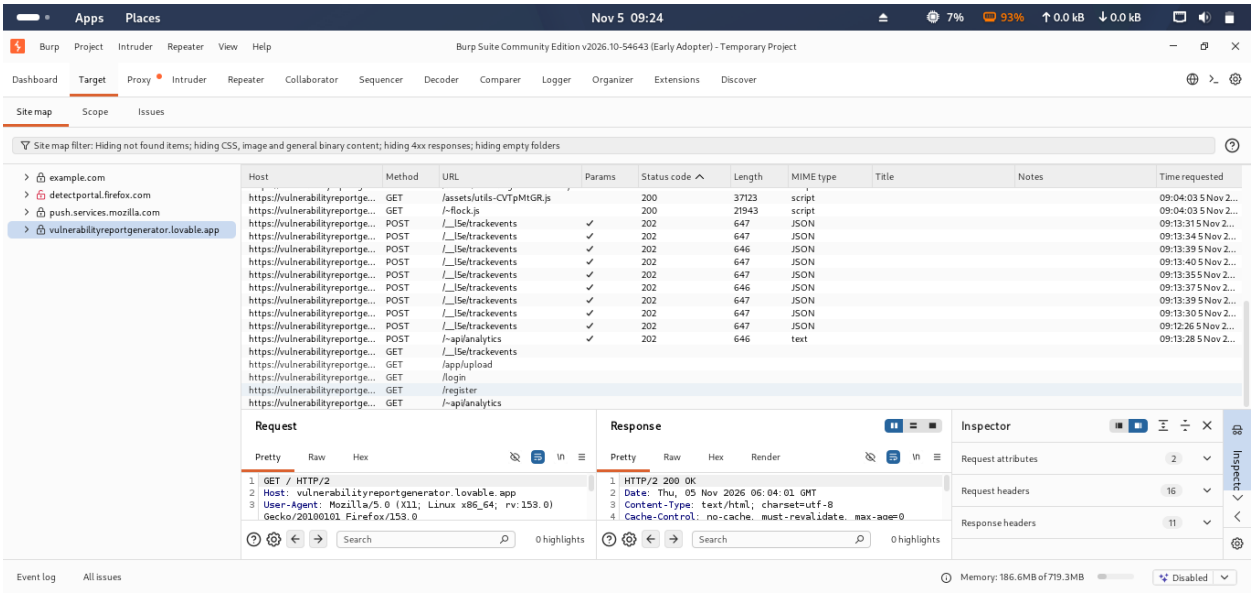


6. Map the application

   Browse every feature such as login, dashboard, upload page, report generation

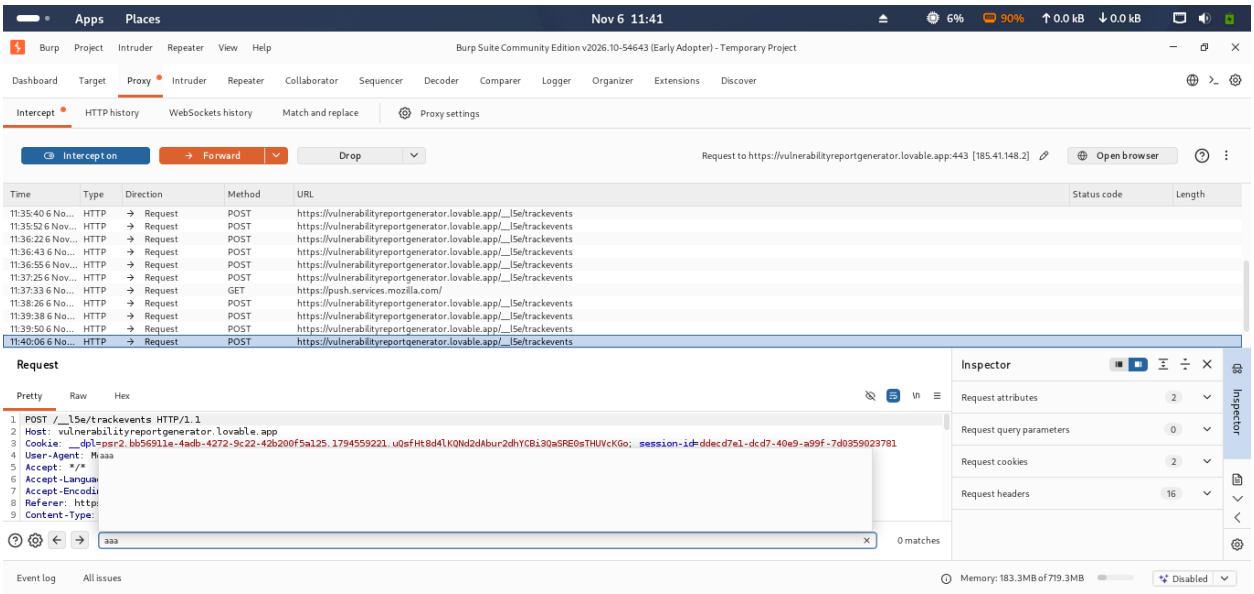
   Burp automatically builds a site map under: **Target->Site Map**

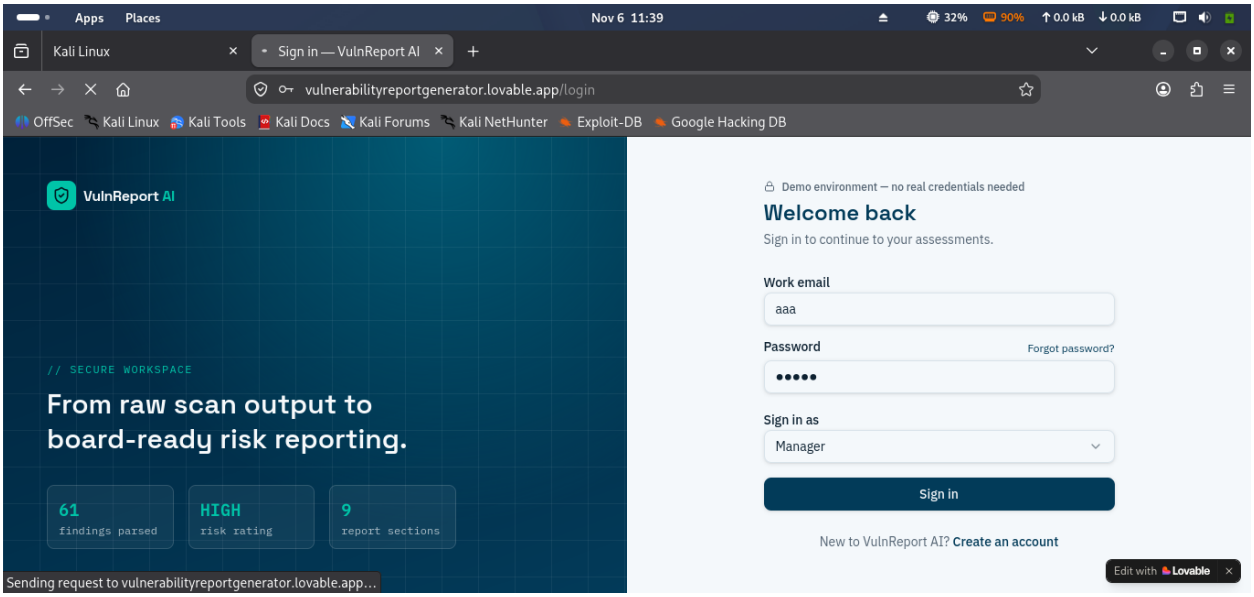
   This helps in discovering hidden routes and APIs.



7. Test login form

   Objective: Try to login with invalid credentials to see if burp suite will intercept the request.

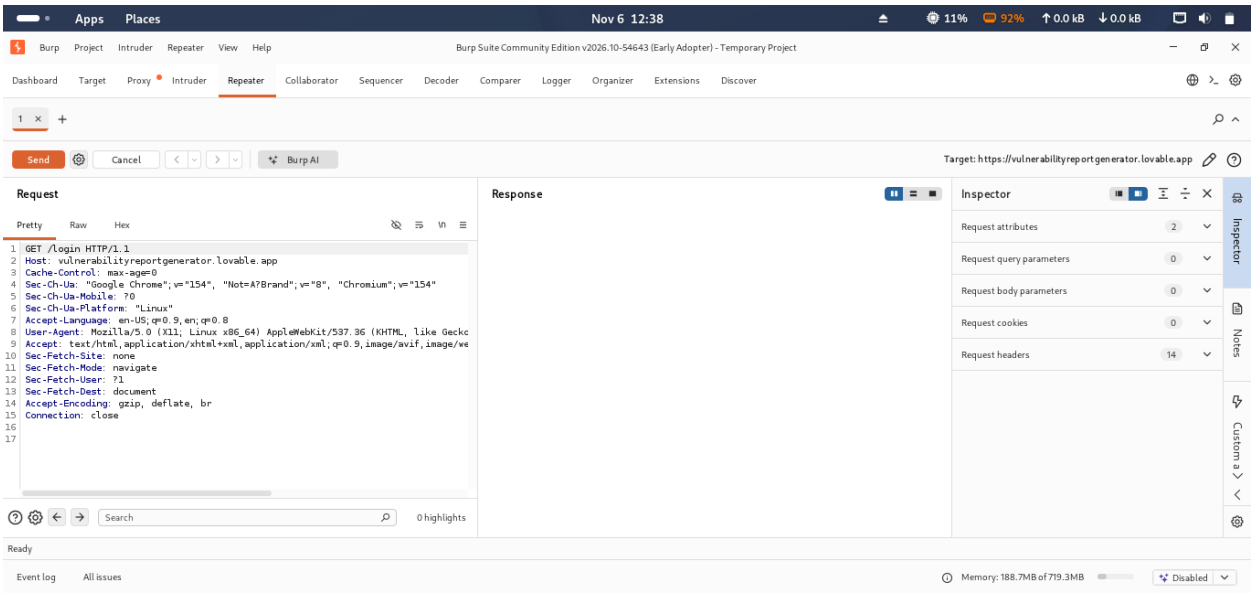




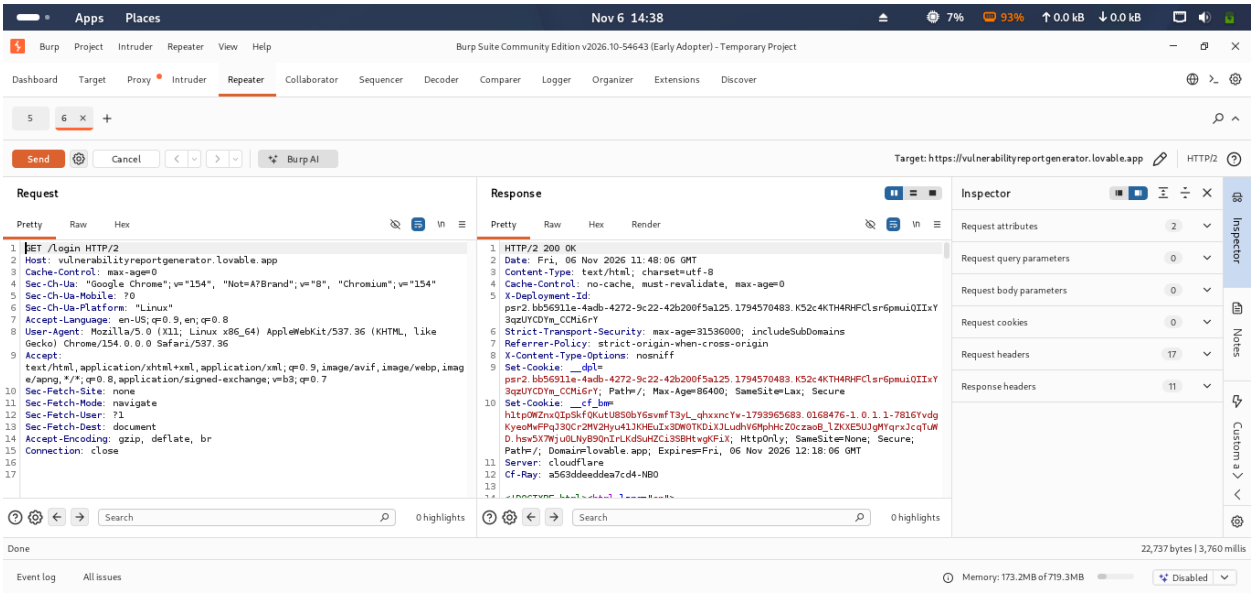
FINDINGS: After changing the email and password in the login form. Burp suite intercepted the HTTP request, however the data being transported wasn't shown hence a sql injection couldn't be performed.

8. Sending the login request to repeater

Objective: To perform manual modification and resending HTTP requests.

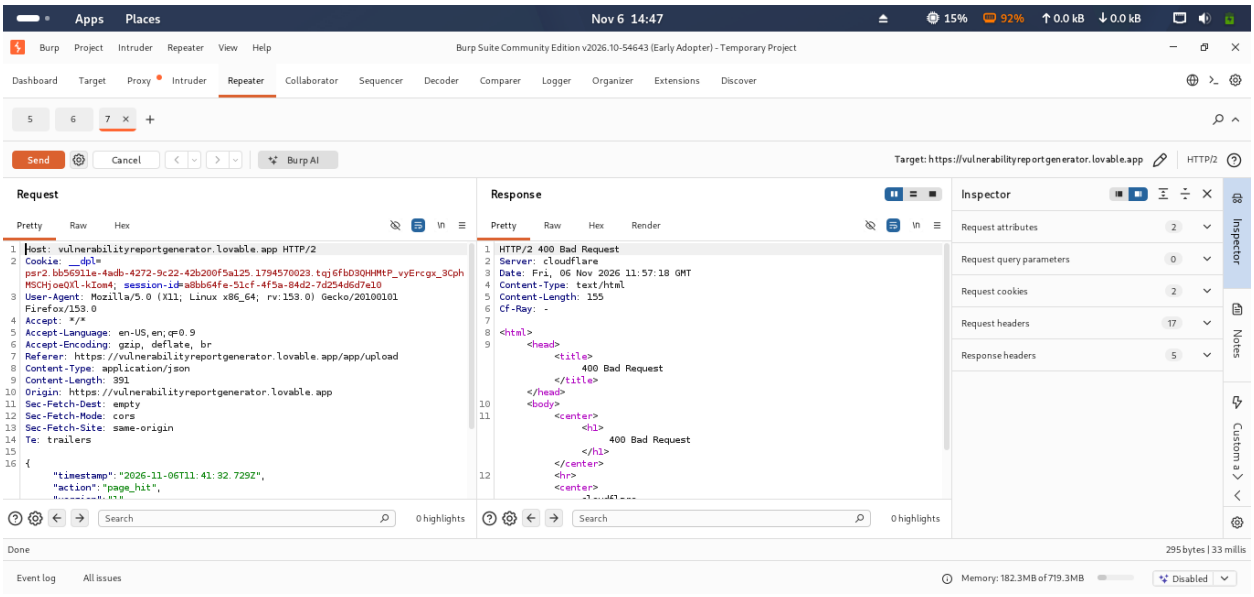


Sending the original file via repeater generates a 202 OK response however the JSON file containing the login credentials isn't shown. Therefore, I'm unable to test login form using credentials not in the database.



9. Testing Authentication Tokens

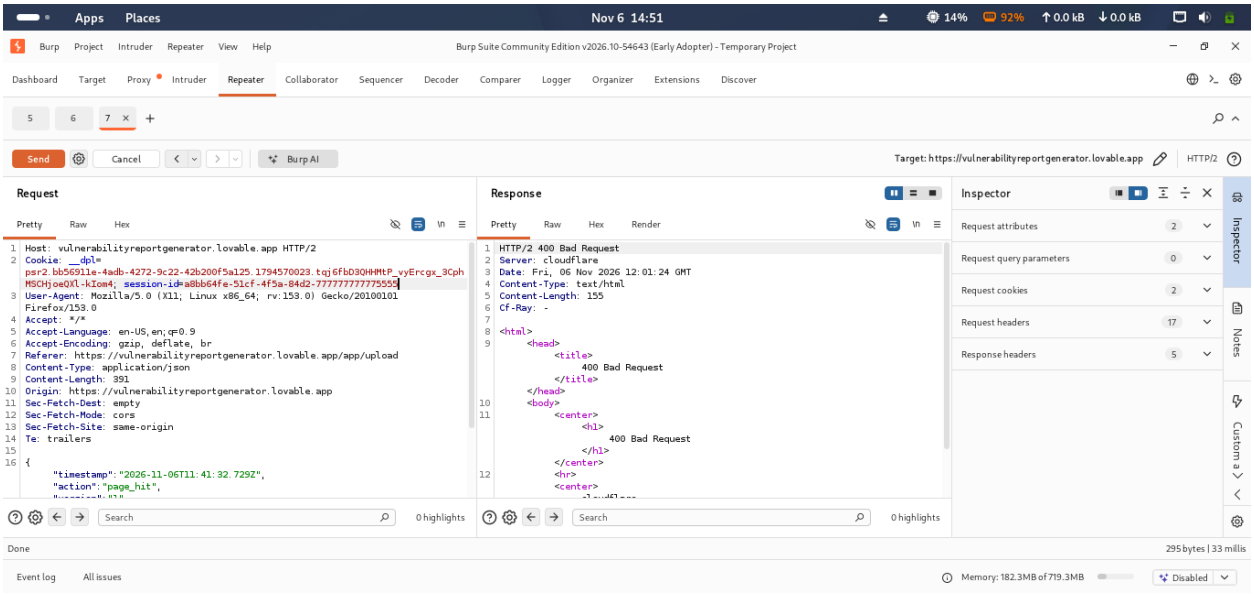
   Objective: Testing authentication by removing token(cookies).eg: GET /api/analytics, then sending.



   Finding: 400 bad request, indicates authentication enforcement exists.

10. Testing expired tokens/invalid tokens

    Objective: Replace available token with invalid token and click send.



Findings: 400 bad request error.